SAST и SCA: результаты и устранение

Отчёт фиксирует проверку статической безопасности (SAST) и зависимостей (SCA). Прогон выполнен в рамках чек-листа ЛЦТ (блок 3.2) и повторяется в CI на каждый push (job `security` в `.github/workflows/ci.yml`).

Дата прогона: 23.09.2026.

1. SAST — Bandit

```
python -m bandit -c pyproject.toml -r backend/ -f txt
```

Метрика	Значение
Просканировано строк	5 229
High	0
Medium	0
Low	0

Что было найдено и как устранено

Правило	Место	Оценка	Решение
B110 (try/except/pass)	`backend/main.py`, `backend/middleware/audit.py`	Ложная суть: подавление ожидаемых ошибок	Заменено на явный `contextlib.suppress(...)` с поясняющим комментарием
B101 (assert)	`backend/services/guide_pdf.py`	`assert` удаляется при `-O`	Переписано на `elif bullet_match is not None` без `assert`
B406 (xml.sax escape)	`backend/services/guide_pdf.py`	Не разбор XML	`escape()` здесь экранирует пользовательский текст перед вставкой в reportlab, а не парсит недоверенный XML — исключено в `[tool.bandit].skips` с обоснованием
B105 (hardcoded password)	`backend/core/config.py`	Значение-заглушка dev	В production валидатор запрещает дефолтный ключ и ключи короче 32 символов — исключено в `skips` с обоснованием

Итог: активных SAST-находок нет. Оставшиеся исключения задокументированы в `pyproject.toml` вместе с причинами, а не «молча заглушены».

2. SCA — Python (`pip-audit`)

```
python -m pip_audit --progress-spinner off
```

Было

124 известных уязвимости в 7 пакетах, в том числе `cryptography` (44.0.0), `pypdf` (5.1.0), `python-jose` (3.3.0), `python-multipart` (0.0.20), `starlette` (0.41.3).

Стало

```
Found 2 known vulnerabilities in 1 package
ecdsa  0.19.2  PYSEC-2026-1325
```

Что обновлено

Пакет	Было	Стало	Причина
`fastapi`	0.115.6	0.141.1	тянет исправленный Starlette
`starlette`	0.41.3	1.7.0 (через FastAPI)	path traversal и др.
`prometheus-fastapi-instrumentator`	7.0.0	8.1.0	совместимость с новым Starlette (7.x падал на `_IncludedRouter`)
`python-jose[cryptography]`	3.3.0	3.5.0	алгоритмические CVE JOSE
`python-multipart`	0.0.20	0.0.31	ReDoS/DoS в парсере форм
`cryptography`	44.0.0	50.0.1	серии PYSEC-2026
`pypdf`	5.1.0	6.19.0	MRO/парсинг PDF
`pytest` / `pytest-asyncio`	8.3.4 / 0.25.0	9.1.1 / 1.4.0	PYSEC-2026-1845

Остаточный риск

`ecdsa 0.19.2` (PYSEC-2026-1325) фикса не имеет — это транзитивная зависимость `python-jose`, используемая только при проверке токенов на EC-ключах. Система подписывает JWT алгоритмом **HS256** (`settings.algorithm`, `backend/auth/security.py`), поэтому ветка кода с `ecdsa` не вызывается. При переходе на ES256/RS256 пакет нужно заменить на `cryptography`-реализацию.

3. SCA — Frontend (`npm audit`)

Было

6 уязвимостей (1 critical, 1 high, 4 moderate): `jspdf` (critical, PDF injection, ReDoS, path traversal), `vite` (high, обход `server.fs.deny`), `react-router`/`react-router-dom` (moderate, open redirect), `dompurify`, `esbuild` (moderate).

Стало

```
found 0 vulnerabilities
```

Что обновлено

Пакет	Было	Стало	Причина
`jspdf`	2.5.2	4.2.1	critical: PDF injection, ReDoS, path traversal
`vite`	5.0.8	7.3.6	high: обход `server.fs.deny`, path traversal
`@vitejs/plugin-react`	^4.2.1	^5.2.0	совместимость с Vite 7
`react-router-dom`	6.20.0	7.18.4	open redirect, constructor injection

`npm run build` и `npx tsc --noEmit` после обновлений проходят; бэкенд-тесты — 94 passed.

4. Повторяемость

Обе проверки запускаются автоматически:

```
# .github/workflows/ci.yml, job security
- pip-audit -r backend/requirements.txt
- npm audit --audit-level=high
```

Job помечен `continue-on-error: true`: новые advisories публикуются ежедневно и не должны блокировать сборку, но факт наличия уязвимостей виден в логе CI. Bandit — кандидат на добавление отдельным шагом при переходе на ежедневные сборки.